

# Gruppenaufgabe 3 | Konzeptionelle Grundlagen und die 3-2-1-Regel der Datensicherung

## Szenario

Die «MedizinTech Zürich GmbH» produziert hochspezialisierte chirurgische Instrumente. In der Branche häufen sich Fälle von massiven Ransomware-Angriffen, bei denen Produktionspläne verschlüsselt und Backups gezielt gelöscht wurden. Die bisherige Sicherung erfolgt ausschliesslich auf einem lokalen NAS-Gerät. Die IT-Leitung hat Sie beauftragt, ein neues, widerstandsfähiges Datensicherungskonzept zu entwerfen, welches die Produktionspläne zwingend vor Verschlüsselungstrojanern und lokalen Brandkatastrophen schützt.

## Lernziele

Nach Bearbeitung dieser Aufgabe können Sie:

- Die klassische 3-2-1-Regel auf ein konkretes, bedrohtes Unternehmensszenario anwenden.
- Unterschiedliche Speichermedien evaluieren und zur Umsetzung der 3-2-1-Regel passend kombinieren.
- Moderne Schutzmechanismen wie Air-Gapping und Immutability konzeptionell in ein Backup-Design integrieren.

## Arbeitsauftrag

Entwickeln Sie in Ihrer Gruppe eine zukunftssichere Backup-Architektur nach der 3-2-1-Regel für die Produktionsdaten der «MedizinTech Zürich GmbH». Bestimmen Sie konkret, welche drei Kopien existieren, welche zwei unterschiedlichen Medientypen Sie nutzen und wie Sie den Offsite-Standort sowie den Ransomware-Schutz (Air-Gap/Immutability) umsetzen.

## Ergebnis

Erstellen Sie eine Architekturskizze auf einem Flipchart und präsentieren Sie (in max. 4 Minuten) den Datenfluss und die konkreten Sicherheitsbarrieren gegen Ransomware.

## Musterlösung A | Gruppenaufgabe 3 | Konzeptionelle Grundlagen und die 3-2-1-Regel der Datensicherung

**Ansatz:** Strukturiert-analytisch

### Systematische Anwendung der 3-2-1-Regel

Die Anforderungen der «MedizinTech Zürich GmbH» verlangen nach einer strikten und kompromisslosen Umsetzung der etablierten 3-2-1-Regel. Der bisherige Zustand

(Produktivdaten plus ein lokales NAS) stellt ein massives Single-Point-of-Failure-Risiko dar. Eine Ransomware, die das Netzwerk kompromittiert, würde innerhalb von Minuten die Produktionsdaten auf den Servern verschlüsseln und danach direkt auf das verbundene NAS überspringen. Das Resultat wäre ein Totalverlust. Unser analytisches Architekturkonzept bricht die Lösung in die drei Bestandteile der Regel auf und definiert exakte technische Parameter.

### **Bestandteil "3": Drei Kopien der Daten**

Um Redundanz zu schaffen, stellen wir sicher, dass zu jedem Zeitpunkt mindestens drei gültige Datensätze der kritischen Produktionspläne existieren:

1. **Kopie 1 (Produktivdaten):** Dies sind die Live-Daten, die auf den primären Hochleistungs-Flash-Speichern im lokalen Rechenzentrum liegen. Hier arbeiten die Ingenieure tagtäglich.
2. **Kopie 2 (Lokales Backup):** Die erste Sicherungskopie. Wir ersetzen das einfache NAS durch einen dedizierten Backup-Server (z.B. basierend auf Linux mit einem robusten Dateisystem wie ZFS oder ReFS), der täglich inkrementelle und wöchentliche Full-Backups zieht. Diese Kopie dient der schnellen Wiederherstellung (kurze RTO), falls ein Mitarbeiter versehentlich eine Datei löscht.
3. **Kopie 3 (Offsite Backup):** Eine exakte Replikation des Backups, welche das Firmengelände verlässt. Diese Kopie rettet das Unternehmen, falls Kopie 1 und 2 zeitgleich zerstört werden (z.B. durch Brand, Löschwasser oder gezielte Hackerangriffe auf das Firmennetzwerk).

### **Bestandteil "2": Zwei unterschiedliche Medientypen**

Diversifikation schützt vor Seriendefekten und protokollbasierten Angriffen. Wir implementieren folgende Medientypen:

- **Medium 1 (Disk/Festplatten):** Die Kopie 2 liegt auf herkömmlichen, rotierenden magnetischen Festplatten (HDDs) in einem RAID-Verbund. Dies garantiert schnelle Schreib- und Lesegeschwindigkeiten für den IT-Support im Tagesgeschäft.
- **Medium 2 (S3-kompatibler Object Storage):** Für die dritte Kopie nutzen wir keinen weiteren Festplattenserver, sondern cloudbasierten Object Storage. Diese Technologie nutzt völlig andere Speicher- und Zugriffsprotokolle (HTTPS/S3 API statt SMB/NFS). Wenn eine Ransomware das Windows-Netzwerk angreift, kann sie mit dem S3-Protokoll nativ nichts anfangen. Dies ist ein massiver technologischer Medienbruch, der die Sicherheit enorm erhöht.

### **Bestandteil "1": Ein Offsite-Standort inkl. Ransomware-Schutz**

Der Offsite-Standort wird nicht durch eine zweite Filiale der MedizinTech realisiert, sondern durch ein zertifiziertes Rechenzentrum eines Schweizer Cloud-Providers in den Schweizer Alpen. Dies garantiert die Einhaltung rechtlicher Rahmenbedingungen (Datenschutz, Standort Schweiz) und schützt vor lokalen Desastern am Hauptsitz in Zürich.

## Der absolute Ransomware-Schutz: Immutability (Unveränderbarkeit)

Um den Schutz gegen Ransomware perfekt zu machen, integrieren wir das Konzept des virtuellen Air-Gaps. Die Backups, die in die Schweizer Cloud (Medium 2 / Offsite) geschrieben werden, erhalten über die S3-Objektsperre (Object Lock) das Attribut "Immutable" (Unveränderbar) für 30 Tage. Das bedeutet:

- Selbst wenn ein Hacker die vollen Administratorenrechte der Backup-Software in Zürich erlangt, ist es ihm rein technisch unmöglich, die Daten in der Cloud zu löschen, zu überschreiben oder zu verschlüsseln.
- Das Cloud-System blockiert jeden Modifikationsversuch auf API-Ebene für die definierten 30 Tage absolut strikt.

## Fazit der Architektur

Die entworfene Architektur erfüllt nicht nur die klassische 3-2-1-Regel (Produktion + Lokal HDD + Cloud S3), sondern erweitert sie um modernste Immutability-Konzepte. Das Management der «MedizinTech Zürich GmbH» kann sich darauf verlassen, dass selbst bei einer vollständigen Übernahme des lokalen Netzwerks durch Kriminelle stets eine unangetastete, unverschlüsselte und rechtssichere Kopie der Produktionspläne im Schweizer Gebirgsmassiv überlebt, aus welcher der Betrieb jederzeit wiederhergestellt werden kann.

## Musterlösung B | Gruppenaufgabe 3 | Konzeptionelle Grundlagen und die 3-2-1-Regel der Datensicherung

**Ansatz:** Praxisnah-narrativ

### Die aktuelle Gefahrenlage begreifen

Wenn wir das Szenario bei der «MedizinTech Zürich GmbH» betrachten, müssen wir schonungslos ehrlich sein: Ein simples NAS im selben Rack wie die Produktionsserver ist kein Backup. Es ist eine Einladung an Kriminelle. Moderne Ransomware-Gruppen gehen heute äusserst raffiniert vor. Sie infiltrieren das Netzwerk, bleiben oft wochenlang unbemerkt (Sneak-In-Phase), suchen gezielt nach den Backup-Speichern und verschlüsseln erst die Sicherung (das NAS), bevor sie die Live-Daten der Produktion attackieren. Wenn das Unternehmen dann am Montagmorgen den Erpresserbrief auf dem Bildschirm sieht, gibt es kein Netz doppeltem Boden mehr. Genau deshalb brauchen wir eine pragmatische, aber kompromisslose Umsetzung der 3-2-1-Regel mit einem echten, harten Air-Gap. Wir müssen Barrieren bauen, die ein Hacker nicht überwinden kann.

### Der Architektur-Entwurf im Praxis-Alltag

*Die 3 Kopien: Das Sicherheitsnetz*

Wir etablieren drei Daseinsformen der Konstruktionspläne. Zuerst natürlich die **Produktionsdaten**, mit denen die Konstrukteure aktuell arbeiten (Kopie 1).

Jede Nacht läuft dann das primäre Backup. Wir belassen das alte NAS vorerst im Einsatz, aber wir hängen es in ein völlig isoliertes Backup-VLAN, auf das kein Konstrukteur und kein normaler Büro-Rechner Zugriff hat. Das ist unsere **zweite Kopie**. Sie dient dazu, schnell eingreifen zu können, wenn jemand am Dienstag um 14 Uhr meldet: "Ich habe meinen CAD-Plan überschrieben." Der IT-Support holt die Daten vom lokalen NAS zurück. Die RTO ist hier fantastisch kurz.

Doch was passiert, wenn die Ransomware auch das Backup-VLAN überwindet? Dann brauchen wir die Lebensversicherung der Firma: Die **dritte Kopie**.

### *Die 2 Medientypen & das echte Air-Gap*

Hier weichen wir im narrativen Ansatz bewusst von reinen Cloud-Lösungen ab und gehen "Old School", weil es im Ernstfall am besten funktioniert. Wir nutzen klassische Magnetbänder (Tape). Tapes sind unser zweites Medium. Warum? Weil Tapes das einzige Medium sind, das ein zu 100% verlässliches, physisches Air-Gap bietet.

Der Prozess sieht wie folgt aus: Der Backup-Server kopiert die Daten am Wochenende vom lokalen NAS auf ein LTO-Laufwerk (Linear Tape-Open). Am Montagmorgen entnimmt der verantwortliche IT-Administrator das Band physisch aus dem Laufwerk. Ein Band, das auf dem Tisch liegt, hat keine IP-Adresse, keinen Stromanschluss und kein Betriebssystem. Eine Ransomware, egal wie hoch entwickelt sie ist, kann keine Daten über die Raumluft verschlüsseln. Dieses physische Air-Gap ist die stärkste Verteidigungslinie, die MedizinTech aufbauen kann.

### *Der 1 Offsite-Standort*

Damit die Bänder nicht bei einem Brand im Serverraum mitsamt den primären Servern schmelzen, müssen sie zwingend ausgelagert werden. Wir etablieren einen einfachen, aber strengen Prozess: Der IT-Leiter schliesst jeden Freitagabend die Tapes der Woche in einen feuersicheren, wasserdichten Datenschutztresor im Keller eines anderen Firmengebäudes ein. Noch professioneller: Wir beauftragen einen externen Sicherheitskurier (z.B. Securitas), der die verschlüsselten Bänder einmal pro Woche abholt und in einen speziellen Bunker einlagert.

### **Argumentation vor dem Management (Der Pitch)**

Wir zeichnen den Ablauf auf dem Flipchart auf und erklären der Geschäftsleitung das Ernstfall-Szenario: "Stellen Sie sich vor, alle Bildschirme leuchten rot. Die Hacker verlangen zwei Millionen Franken in Bitcoin. Wir trennen die Firma sofort vom Internet. Die Live-Daten sind verschlüsselt. Wir schauen auf unser lokales Backup-NAS: Die Hacker haben es gefunden und

ebenfalls zerstört. Wir sind blind. Aber dann gehen wir an den Safe. Wir holen das Magnetband von letzter Woche heraus. Es lag völlig stromlos und unantastbar im Tresor. Wir schieben es in einen frischen Server. Wir haben die Pläne, wir haben die Kontrolle und wir zahlen keinen einzigen Rappen an Kriminelle. Das ist die Macht der 3-2-1-Regel kombiniert mit einem echten Air-Gap. Es rettet Ihre Firma, wenn alle anderen technischen Firewalls versagt haben."